

数飞科技(宁波)有限公司

国泰新点大OA系统运维服务项目

信息安全管理计划

文档编号	SFKJ-ITSS-0615	版本	V1.0
作者	汪锦坤	编辑日期	2026.01.10
审核	马盛艳	审核日期	2026.01.10
批准	陶飞	批准日期	2026.01.10
发布范围	内部	发布日期	2026.01.10

文档修订信息

版本号	修订日期	修订人	修订说明	备注
V1.0	2026.01.10	汪锦坤	新增	

目录

1. 目的	4
2. 适用范围	4
3. 信息安全目标	4
4. 信息安全组织与职责	4
5. 信息资产识别与分类	5
5.1. 信息资产清单	5
5.2. 信息资产分级	5
6. 信息安全风险评估	6
6.1. 主要风险识别	6
6.2. 风险应对措施	6
7. 信息安全管理措施	6
7.1. 访问控制管理	6
7.2. 数据安全保护	7
7.3. 网络安全防护	7
7.4. 系统安全加固	7
7.5. 物理安全防护	7
7.6. 人员安全管理	7
8. 信息安全事件管理	8
8.1. 事件分级	8
8.2. 事件响应流程	8
9. 信息安全培训与意识	8
10. 信息安全检查与审计	8

表目录

表 4-1 信息安全组织职责表	4
-----------------------	---

1. 目的

为保障《国泰新点大OA系统运维服务项目》项目在服务期内的信息安全，确保信息资产的机密性、完整性和可用性，防范信息安全风险，满足客户安全需求和法律法规要求，特制定本计划。

2. 适用范围

本计划适用于本项目运维服务全过程中与信息安全管理相关的活动，涵盖以下范围：

- 1. 信息系统：国泰新点大OA系统运维服务项目、数据库、监控系统
- 2. 基础设施：服务器、网络设备、服务器、网络设备
- 3. 数据资产：业务数据、配置数据、日志数据、备份数据
- 4. 人员：项目运维人员、管理人员、第三方支持人员
- 5. 场所：数据中心、办公区、客户客户现场现场

3. 信息安全目标

本计划设定以下信息安全目标，作为项目安全管理的工作指引：

- 1. 信息安全事件：全年0次因我方人员造成的信息安全事件
- 2. 数据备份：关键数据每日备份成功率达到100%
- 3. 访问控制：权限申请、变更、回收符合流程要求
- 4. 漏洞修复：高危漏洞在发现后7天内完成修复
- 5. 安全培训：项目运维人员年度安全培训覆盖率达到100%

4. 信息安全组织与职责

表 4-1 信息安全组织职责表

角色	岗位	职责
信息安全管理负责人	运维部经理	负责项目信息安全整体管理，审批安全策略，监督安全措施执行
信息安全执行人	运维项目经理	负责日常安全管理工作，组织风险评估，协调安全事件处理

角色	岗位	职责
系统安全责任人	软件运维工程师	负责系统安全配置、漏洞修复、访问控制管理
网络安全责任人	硬件运维工程师	负责网络设备安全配置、防火墙策略、入侵检测
数据安全责任人	软件运维工程师	负责数据备份、数据加密、数据恢复验证
物理安全责任人	硬件运维工程师	负责机房及设备物理安全、门禁管理
安全监督人	质量部专员	负责安全合规检查、安全审计

5. 信息资产识别与分类

5.1. 信息资产清单

项目主要信息资产包括以下几类：

软件资产：大OA系统、达梦数据库、东方通中间件、监控系统

硬件资产：应用服务器、数据库服务器、网络设备（路由器、交换机）、服务器、网络设备

数据资产：业务数据（OA系统业务数据、配置数据）、配置数据、日志数据、备份数据

文档资产：技术文档、操作手册、安全策略、应急预案

5.2. 信息资产分级

根据信息资产的重要程度和影响范围，划分为三个安全等级：

高等级资产：客户业务数据、数据库、系统核心配置、授权文件。此类资产泄露或损坏将造成严重影响，需采取最高级别保护措施，包括存储加密、传输加密、严格访问控制。

中等级资产：系统配置、监控数据、技术方案、运维报告。此类资产泄露或损坏将造成一定影响，需采取标准安全保护措施。

低等级资产：日常记录、培训资料、日志文件。此类资产影响较小，采取基础安全保护措施即可。

6. 信息安全风险评估

6.1. 主要风险识别

项目面临的主要信息安全风险包括：

技术风险：系统漏洞可能被利用导致数据泄露或系统入侵；数据库遭受攻击；网络入侵造成服务中断。

数据风险：客户数据泄露；数据丢失或损坏；备份失效无法恢复。

人员风险：权限滥用造成数据泄露；操作失误导致配置错误；离职人员泄密。

环境风险：机房未经授权进入；中间件被盗。

6.2. 风险应对措施

针对识别的高风险项，采取以下应对措施：

系统漏洞风险：定期进行漏洞扫描，及时安装安全补丁，高危补丁在7天内完成安装

数据安全风险：每日全量备份并异地存储，每周验证备份可用性；高密级数据存储加密，传输使用HTTPS/SSH

访问控制风险：遵循最小权限原则，账户申请需经审批，离职人员权限及时回收，每季度审计账户权限

网络安全风险：配置防火墙最小开放原则，部署入侵检测系统，远程运维通过VPN接入

7. 信息安全管理措施

7.1. 访问控制管理

访问控制遵循“最小权限、按需分配、定期审计”的原则。所有账户申请需经运维部经理审批，离职人员权限在离职当日完成回收。密码策略要求密码长

度不少于8位，包含大小写字母、数字和特殊字符，每90天强制更换。特权账户仅授权特定人员使用，所有操作需记录日志。质量部专员每季度对账户权限进行审计，及时清理过期账户。

7.2. 数据安全

数据安全管理的核心是确保数据的机密性、完整性和可用性。业务数据每日进行全量备份，保留周期为30天，同时执行异地备份以防本地灾难。每周验证备份数据的可用性，每季度组织数据恢复演练。高密级数据在存储和传输过程中均进行加密，使用HTTPS或SSH协议。数据销毁需经审批，物理介质销毁时留有记录。

7.3. 网络安全

网络防护措施包括：生产环境与办公环境进行网络隔离，防止非授权访问；防火墙采用最小开放原则，仅开放业务必要端口；远程运维通过VPN接入，并启用多因素认证；部署入侵检测系统，定期分析告警日志。

7.4. 系统安全

系统安全方面，每月检查系统补丁状态，高危补丁在7天内完成安装。服务器部署防病毒软件，定期更新病毒库。系统日志保留90天，定期审计异常访问。遵循最小化安装原则，仅安装必要软件和服务，禁用默认账户，删除测试账户。

7.5. 物理安全

物理安全措施包括：机房设置门禁系统，出入需登记，非授权人员进入需有专人陪同。服务器上锁固定，中间件安装于安全位置。机房配置温湿度监控、UPS电源和空调监控，确保环境稳定。设备报废前彻底清除数据，留有销毁记录。

7.6. 人员安全

人员安全管理覆盖员工全生命周期。入职时签订保密协议，接受安全培训；在职期间定期参加安全培训，明确岗位安全职责；离职时回收所有权限，交接资产，签署离职保密承诺书。第三方人员需签署保密协议，按最小权限原则授权，定期评估其服务安全性。

8. 信息安全事件管理

8.1. 事件分级

安全事件根据影响程度分为三个等级：

一级（重大）：数据泄露、系统被入侵、服务中断，需立即响应，15分钟内上报副总经理

二级（严重）：权限滥用、病毒爆发、数据损坏，需30分钟内上报运维部经理并启动应急

三级（一般）：异常访问、配置错误、告警触发，需2小时内处理完成

8.2. 事件响应流程

安全事件响应遵循以下流程：发现事件后立即上报；确认事件类型和影响范围；执行应急预案控制影响；恢复系统并验证安全性；事后分析原因，制定改进措施。所有事件处理过程需完整记录，作为后续改进的输入。

9. 信息安全培训与意识

为提升项目人员的安全意识和操作技能，定期组织安全培训：

入职培训：新员工入职时接受信息安全政策培训，了解基本安全要求

安全操作培训：每半年组织运维人员学习安全操作规范，包括数据保护、权限管理等内容

应急响应演练：每年组织一次应急响应实战演练，验证应急预案有效性

社会工程防范：每年开展社会工程防范培训，提升人员对钓鱼邮件、电话诈骗等攻击的识别能力

10. 信息安全检查与审计

通过多层次检查机制确保安全措施有效执行：

日常检查：每日检查备份状态、日志异常和系统告警

周度检查：每周检查账户权限、系统补丁、病毒库更新情况

月度审计：每月审计访问日志和权限变更记录

季度检查：每季度进行漏洞扫描和安全配置检查

年度评估：每年组织风险评估和安全体系评估

检查发现的问题纳入整改跟踪，确保闭环管理。